

**Zewail City of Science, Technology and Innovation
University of Science and Technology
School of Computational Sciences and
Artificial Intelligence
DSAI 202 Spring 2026**

Mariam Mohamed Goda[202201223]

Karim Mohamed [202401696]

Mariam Mohamed [202508267]

Eyad Eslam [202401218]

Doctor : Sabah Sayed

Brazilian E-Commerce Project Report

[Phase Two: Privacy and Security Implementation]

Zewail City of Science, Technology and Innovation
University of Science and Technology
School of Computational Sciences and
Artificial Intelligence
DSAI 202 Spring 2026

Data Re-Preprocessing :

1. Data Enrichment Strategy (Supplementary Data)

The core Olist dataset, while rich in transactional data, lacked the demographic depth required for a modern governance and marketing analysis framework.

- **Source Integration:** I integrated a secondary **Retail Analysis Large Dataset** to simulate a unified 360-degree customer view.
- **Attribute Expansion:** I mapped and ingested seven new governance-sensitive dimensions:
 - **Contact Info:** customer_email, customer_phone, customer_address.
 - **Demographics:** customer_age, customer_gender, customer_income.
 - **Strategic Segmentation:** customer_segment.
- **Security Simulation:** To test PII (Personally Identifiable Information) governance, I utilized the Faker library to generate synthetic customer_password fields, ensuring the dataset had attributes requiring strict access controls.

2. Re-Processing & Remediation Logic

The re-processing phase focused on transforming "dirty" data into "governed" data. My workflow addressed four key areas:

A. Structural Normalization

- **The Issue:** The customer_phone column was imported in scientific notation (e.g., 5.55E+10), rendering it useless for communication logs.
- **The Fix:** Applied a lambda transformation to coerce these floats into clean, integer-based strings, restoring data usability.

Zewail City of Science, Technology and Innovation
University of Science and Technology
School of Computational Sciences and
Artificial Intelligence
DSAI 202 Spring 2026

Access Control and Privacy Policies

In this part of the project, an Attribute-Based Access Control (ABAC) system was implemented to control access to sensitive customer data inside the dataset.

First, different users were created with different roles and attributes such as: (Admin , Analyst , Marketing and Guest).

Each user has a specific role, department, and clearance level. These attributes help determine what each user is allowed to access.

After that, the sensitive resources in the dataset were identified. These resources included customer email, phone number, address, password, and income. Other fields such as review scores and order status were considered less sensitive.

Then, access policies were created for every role. For example:

- The Admin has full access to all resources and actions.
- The Analyst can only read some analytical data like payment values and review scores.
- The Marketing user can only access limited non-sensitive information.
- The Guest user does not have permission to access protected resources.

A function called `check_access()` was implemented to verify if a user is allowed to perform a specific action on a specific resource. The function checks:

1. If the user exists
2. If the role is configured correctly
3. If the requested action is allowed
4. If the resource can be accessed by that role

The system then returns either access granted or access denied. In addition, an access logging mechanism was added to record all access attempts. The logs store the user name, requested resource, action type, and the final result of the request.

Overall, this implementation helped improve data security by restricting unauthorized access and protecting sensitive customer information.

Zewail City of Science, Technology and Innovation
University of Science and Technology
School of Computational Sciences and
Artificial Intelligence
DSAI 202 Spring 2026

Regulatory Compliance:

Regulatory compliance is the process by which organizations adhere to the laws, regulations, guidelines, and specifications that govern their industry. In the context of data and information management, it means implementing policies and controls to ensure that personal data is collected, stored, used, and deleted in ways that satisfy legal requirements. Non-compliance can result in significant fines, reputational damage, and legal liability.

1. GDPR – General Data Protection Regulation:

- **Scope:** Any organization that processes personal data of EU residents, regardless of where the organization is based.
- **Key Principles:** Lawfulness, fairness, transparency; data minimization; purpose limitation; accuracy; storage limitation; integrity & confidentiality.
- **Individual Rights:** Right to access, right to erasure ("right to be forgotten"), right to portability, right to object.
- **Penalties:** Up to €20 million or 4% of global annual turnover — whichever is higher.

2. CCPA – California Consumer Privacy Act:

- **Scope:** Applies to for-profit businesses that do business in California, collect personal information of California residents, and meet at least one threshold (e.g., annual revenue over \$25M, handle data of a large number of consumers, or earn a significant share of revenue from selling personal data).
- **Key Principles:** Right to know what personal information is collected, used, shared, or sold, delete personal information (with some exceptions), opt out of the sale of personal information, non-discrimination for exercising CCPA rights.
- **Individual Rights:** Consumers can sue after certain data breaches and claim statutory damages (e.g., up to \$750 per affected consumer or actual damages if higher).
- **Penalties:** Civil penalties up to about \$2,500 per unintentional violation and up to \$7,500 per intentional violation, which can multiply across many consumers.

3. HIPAA – Health Insurance Portability and Accountability Act:

- **Scope:** Healthcare providers, health plans, healthcare clearinghouses, and their business associates in the United States.
- **Protected Information:** Protected Health Information (PHI) — any individually

Zewail City of Science, Technology and Innovation

University of Science and Technology

School of Computational Sciences and Artificial Intelligence

DSAI 202 Spring 2026

identifiable health information.

- **Key Rules:** Privacy Rule (use & disclosure of PHI); Security Rule (safeguards for electronic PHI); Breach Notification Rule.
- **Penalties:** 100– 50,000 per violation, up to \$1.9 million per year per category.

3-C · Comparison Table

Feature	GDPR	CCPA	HIPAA
Jurisdiction	European Union	California, USA	United States (healthcare)
Effective Since	May 2018	January 2020	1996 (Privacy Rule 2003)
Covered Data	All personal data of EU residents	Personal data of CA residents	Protected Health Information (PHI)
Industry Scope	All industries	For-profit businesses	Healthcare sector only
Right to Erasure	✓ Explicit	✓ (Right to delete)	Limited
Data Portability	✓ Explicit	✓ (Right to know)	Limited
Opt-out of Data Sale	✓ (Consent-based)	✓ Explicit	N/A
Breach Notification	Within 72 hours to authority	Without unreasonable delay	Within 60 days
Max Penalty	€20M or 4% global revenue	7, 500perintentionalviolation 1.9M per category/year	
Enforcement Body	Data Protection Authorities	California AG / CPPA	U.S. Dept. of Health & Human Services